# Seungpyo Hong

Offensive Security Researcher

newbiepwner@kakao.com Seoul, South Korea phantomn.github.io phantomn ph4nt0m

## Summary

Offensive Security Researcher with 6 years of hands-on penetration testing and vulnerability research. Derived **25 CVEs** (OS Kernel 16 + IoT 5 + LLM 3 + Database 1) through independent fuzzing and reverse engineering. Built an AI Orchestration Framework that autonomously identifies vulnerabilities on live targets - using IDA Pro, Burp Suite, Frida, and CodeQL orchestrated via MCP + A2A. NATO CCDCOE Locked Shields 2025 overall 6th of 17 (DFIR #1).

## Experience

**CoreSecurity**, ICS Security Researcher (Senior)
Seoul, South Korea
June 2021 – present
5 years 5 months

- Triage and validate vulnerabilities across OT/ICS, IoT, and medical device targets
- distinguishing exploitable issues from false positives with reproducible PoCs
- IEC 62443-4-2 Threat Modeling & pentesting
- contributed to LS ELECTRIC Achilles Level 2 certification; delivered structured findings to engineering and certification teams
- Designed and developed automated security assessment tooling for vulnerability detection across smart building IoT infrastructure
- Built AI-driven offensive pipeline (MCP + A2A): orchestrates IDA Pro, Burp Suite, Frida, CodeQL to auto-identify Low–Medium vulnerabilities on live pentest targets
- ELECCON (KEPCO) 2021–2024: 4-year operation of national OT/ICS red-vs-blue exercise
- attack scenario design, PoC development, and blue team evaluation
- **NATO CCDCOE Locked Shields 2025** (Korea-Canada DFIR blue team)
- overall 6th of 17, **DFIR 1st place**
- APEX 2025, 2026 Green Team, DFIR challenge author (May–Sep 2025; 2026)

**A3 Security**, Web/App Pentester
Seoul, South Korea
June 2020 – June 2021
1 year 1 month

- 12 web/app penetration tests against financial and public-sector targets
- delivered reproducible, severity-ranked findings with PoC evidence to clients
- Avg. 1–2 high-risk vulnerabilities per engagement: auth bypass, business logic flaws, privilege escalation
- Reviewed non-standard targets (KT GiGA Genie IoT, NH RPA, thermal sensors)
- adapted methodology to unfamiliar attack surfaces
- Customer-facing reporting and remediation validation
- translated technical findings for engineering and compliance stakeholders

## Education

**BS** **Kongju National University**, Computer Science
Chungnam, South Korea
Feb 2012 – Feb 2020

## Vulnerability Research

**OS Kernel CVEs (16) - Best of the Best 8th Cohort, 2019:** Designed and implemented a custom coverage-guided File System Fuzzer from scratch. Identified, triaged, and reproduced 16 Linux kernel vulnerabilities (0-day + 1-day), including CVSS 7.8 HIGH issues. Delivered PoCs and root cause analysis. Presented at **CodeBlue 2019** (Tokyo) & **Hack In The Box 2019** (Amsterdam). CVE-2019-18885, 19036, 19037, 19039, 19318, 19319, 19377, 19378, 19447, 19448, 19449, 19813, 19814, 19815, 19816, 19927

**IoT CVEs (5) - Independent Research, 2024:** Reverse-engineered embedded firmware; identified and reproduced vulnerabilities with full PoC chains. CVE-2024-33789 & CVE-2024-33792 (CVSS **9.8 CRITICAL**), CVE-2024-33788 (CVSS 8.0 HIGH), CVE-2024-33791 (CVSS 4.6), CVE-2024-33793 (CVSS 5.3)

**LLM Inference Engine CVEs (3) - Independent Research, 2026:** Audited llama.cpp's HTTP server and model loader by fuzzing structured inputs (JSON schemas, GGUF files, REST parameters), then hand-tracing each crash to root cause. CVE-2026-52130 (CVSS **7.5 HIGH**, CWE-674): unbounded recursion in json-schema-to-grammar - reproduced 8 MB stack exhaustion at recursion depth 7000+, and separated the vulnerable path (`/completions`) from the non-vulnerable one (`/v1/chat/completions`, which routes through jinja) to scope impact precisely. CVE-2026-52132 (CVSS **7.5 HIGH**, CWE-190): integer overflow from a negative `top_n` on `/rerank`, driving an oversized allocation and remote DoS. CVE-2026-52131 (CVSS 5.5, CWE-617): reachable assertion in `gguf_reader::read` - a crafted GGUF model aborts the process on load. Each finding shipped with a minimal PoC and an upstream patch-level root cause writeup.

**Bug Bounty - 4 FVEs (FindTheGap):** Black-box web/API testing on live production targets. Four access control and authentication findings: missing authentication permitting account takeover across an entire user base, an unauthorized identity-verification endpoint leaking real names and phone numbers, and unauthenticated APIs enumerable for personal data (CVSS up to **9.8 CRITICAL** CWE-284, CWE-306, CWE-200). All validated with reproducible request chains and reported through coordinated disclosure. Vendor and technical details withheld under program policy.

## Projects

**AI Offensive Security Orchestration Framework** 2024 – present

- Autonomous vulnerability identification pipeline: IDA Pro, Burp Suite, Frida, CodeQL connected via MCP + A2A protocol
- LLM agent triages scan output, separates exploitable findings from noise, generates structured reports
- Validated on live pentest targets
- consistently surfaces Low–Medium findings that manual scans miss
- RAG pipeline (n8n · pgvector) provides real-time context from IEC 62443, ISO 27001, and past exploit patterns

**ELECCON - National OT/ICS Cyber Warfare Exercise** 2021 – 2024

- 4-year consecutive design and operation of KEPCO's national red-vs-blue exercise
- Developed SCADA/PLC exploit scenarios and blue team scoring metrics

**File System Fuzzer (BoB 8th Cohort)** Jan 2019

- Built coverage-guided fuzzer targeting Linux kernel filesystem code → 16 CVEs
- Full exploit chain: fuzzing → crash triage → root cause analysis → PoC → CVE submission

## Skills

**Offensive Tooling:** Burp Suite, IDA Pro, Frida, CodeQL, pwndbg, Metasploit, Nmap, Ghidra, custom scripts

**Vulnerability Research:** Fuzzing (coverage-guided, stateful), exploit development, reverse engineering (firmware/kernel), PoC crafting, root cause analysis

**AI Security Automation:** MCP + A2A orchestration, LangGraph, VoltAgent, n8n, RAG (pgvector), Claude Code

**Pentest Domains:** Web/App, OT/ICS, IoT/Embedded, Medical Device

**Standards & Communication:** IEC 62443-4-2, FDA 510(k)/eSTAR · Korean (Native), English (Professional working)